

Report di Laboratorio

Vulnerability Assessment con Nmap e Nessus

Corso di Cybersecurity & Ethical Hacking

Esercitazione pratica in ambiente di laboratorio virtualizzato

Ambiente:	VirtualBox — Kali Linux + Metasploitable 2
Strumenti:	Nmap, searchsploit, Nessus Essentials
Target:	192.168.1.100 (Metasploitable)
Data:	Maggio 2026

1. Obiettivo dell'esercitazione

L'obiettivo di questa esercitazione era svolgere un **Vulnerability Assessment** completo su un host di test, applicando il flusso di lavoro tipico delle prime fasi di un penetration test: *discovery* della rete, identificazione dei servizi esposti, fingerprinting di sistema operativo e applicazioni, ricerca di vulnerabilità note e infine scansione automatica con un tool professionale.

Ho scelto come bersaglio la macchina **Metasploitable 2**, che è una macchina virtuale Linux volutamente vulnerabile, distribuita proprio a scopo didattico. Operando da Kali Linux ho usato **Nmap** con diverse opzioni (host discovery, scansione delle porte, rilevamento delle versioni, OS detection, scansione aggressiva e script vuln), **searchsploit** per cercare exploit pubblici legati alle versioni rilevate, e infine **Nessus Essentials** per un controllo completo automatizzato.

Il fine didattico era duplice: imparare a usare gli strumenti standard del settore e, soprattutto, imparare a *leggere* e *interpretare* il loro output, perché uno scan vale solo se chi lo lancia capisce cosa restituisce.

2. Ambiente di laboratorio

Il laboratorio è stato realizzato interamente in locale tramite **Oracle VirtualBox**, con due macchine virtuali:

- **Kali Linux** — macchina di attacco. Da qui ho lanciato tutti i comandi Nmap e l'interfaccia web di Nessus.
- **Metasploitable 2** — macchina vittima, basata su Ubuntu, con kernel Linux 2.6.x e una lunga lista di servizi vulnerabili.

Entrambe le VM sono state configurate sulla **stessa subnet** (192.168.1.0/24) in modo che potessero comunicare fra loro e con il router di rete. Questa è stata la prima cosa da verificare: senza una corretta configurazione di rete nessuna scansione avrebbe potuto raggiungere il target.

Nota etica. Tutti i test sono stati condotti su una macchina volutamente vulnerabile e di mia proprietà, all'interno di una rete di laboratorio isolata. Eseguire le stesse scansioni su sistemi di terzi, senza autorizzazione scritta, costituisce un reato.

3. Strumenti utilizzati

3.1 Nmap

Nmap (Network Mapper) è lo strumento di riferimento per network scanning e host discovery. Permette di scoprire host attivi, mappare le porte aperte, identificare i servizi e le loro versioni, fare fingerprinting del sistema operativo e, tramite il suo motore NSE (Nmap Scripting Engine), eseguire script di verifica vulnerabilità.

3.2 searchsploit

searchsploit è il client a riga di comando di Exploit-DB. Una volta che Nmap mi dà la versione di un servizio, con searchsploit posso cercare se esistono exploit pubblici noti per quella versione specifica.

3.3 Nessus Essentials

Nessus Essentials è la versione gratuita del vulnerability scanner di Tenable. Rispetto a Nmap copre molte più verifiche applicative e fornisce un report categorizzato per gravità (Critical, High, Medium, Low, Info), molto utile per presentare i risultati.

4. Procedura svolta

Di seguito ripercorro tutti gli step nell'ordine in cui li ho effettivamente eseguiti, riportando il comando, lo screenshot dell'output e la mia interpretazione dei risultati.

Step 1 — Configurazione delle macchine virtuali

Prima di qualsiasi scansione mi sono assicurato che Kali e Metasploitable fossero raggiungibili reciprocamente. Le ho posizionate sulla stessa subnet 192.168.1.0/24 e ho verificato la connettività con un semplice ping dalla Kali verso l'IP che il DHCP aveva assegnato a Metasploitable. Senza questa verifica preliminare, qualunque scan successivo avrebbe rischiato di restituire risultati ingannevoli (host "down" non perché spento, ma perché irraggiungibile a livello di rete).

Step 2 — Host discovery sulla LAN

```
$ nmap -sn 192.168.1.0/24
```

Con la flag -sn (ping scan, niente port scan) ho mappato tutti gli host attivi sulla rete locale. Questa è la fase di *discovery*: serve a sapere chi c'è prima di approfondire.

Tra i 14 host rilevati ho riconosciuto immediatamente la mia Metasploitable dal MAC address, che inizia con 08:00:27: il prefisso OUI di Oracle VirtualBox. L'IP assegnato risulta essere **192.168.1.100**, che userò come bersaglio in tutti gli step successivi.

```
(kali@kali)~$ nmap -sn 192.168.1.0/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-07 09:34 -0400
Nmap scan report for H388X.homenet.telecomitalia.it (192.168.1.1)
Host is up (0.0042s latency).
MAC Address: 3C:A7:AE:8E:06:FC (zte)
Nmap scan report for NOMI-IPC-TA42-D.homenet.telecomitalia.it (192.168.1.2)
Host is up (1.1s latency).
MAC Address: E4:24:6C:9E:1D:B7 (Zhejiang Dahua Technology)
Nmap scan report for SG2008P.homenet.telecomitalia.it (192.168.1.3)
Host is up (0.010s latency).
MAC Address: 74:FE:CE:73:42:E1 (TP-Link Systems)
Nmap scan report for 192.168.1.5 (192.168.1.5)
Host is up (1.1s latency).
MAC Address: 20:23:51:88:24:68 (TP-Link Systems)
Nmap scan report for 192.168.1.6 (192.168.1.6)
Host is up (0.75s latency).
MAC Address: 20:23:51:88:24:5E (TP-Link Systems)
Nmap scan report for 192.168.1.7 (192.168.1.7)
Host is up (0.0051s latency).
MAC Address: 20:23:51:88:24:66 (TP-Link Systems)
Nmap scan report for Host-010.homenet.telecomitalia.it (192.168.1.14)
Host is up (0.24s latency).
MAC Address: 90:98:77:08:AF:79 (Vestel Elektronik San ve Tic. A.S.)
Nmap scan report for TOSHIBA-TV.homenet.telecomitalia.it (192.168.1.15)
Host is up (0.0051s latency).
MAC Address: 54:DE:1B:7D:E2:DA (Vestel Elektronik San ve Tic. A.S.)
Nmap scan report for LV-Laptop.homenet.telecomitalia.it (192.168.1.47)
Host is up (0.00033s latency).
MAC Address: 1C:79:2D:87:F1:39 (China Dragon Technology Limited)
Nmap scan report for Host-002.homenet.telecomitalia.it (192.168.1.51)
Host is up (0.32s latency).
MAC Address: 28:AD:18:D1:1B:9D (Hui Zhou Gaoshengda Technology)
Nmap scan report for GoogleTV3272.homenet.telecomitalia.it (192.168.1.54)
Host is up (0.10s latency).
MAC Address: 50:E4:78:15:89:7E (Sichuan AT-Link Technology)
Nmap scan report for 192.168.1.100 (192.168.1.100)
Host is up (0.0064s latency).
MAC Address: 08:00:27:13:2C:A8 (Oracle VirtualBox virtual NIC)
Nmap scan report for Host-001.homenet.telecomitalia.it (192.168.1.114)
Host is up (0.047s latency).
MAC Address: EC:BE:5F:6C:69:6B (Vestel Elektronik San ve Tic. A.S.)
Nmap scan report for Host-013.homenet.telecomitalia.it (192.168.1.69)
Host is up.
Nmap done: 256 IP addresses (14 hosts up) scanned in 13.43 seconds
```

Figura 1 — Output di `nmap -sn 192.168.1.0/24`. Evidenziato in rosso l'host Metasploitable (192.168.1.100, MAC Oracle VirtualBox).

Cosa ho osservato:

- 14 host attivi nella LAN, tipici di una rete domestica.
- Il MAC address con OUI 08:00:27 identifica univocamente una scheda virtuale VirtualBox.
- L'IP target del lab è **192.168.1.100**.

Step 3 — TCP SYN scan sulle porte di Metasploitable

```
$ sudo nmap -sS 192.168.1.100
```

Una volta individuato l'IP del target, ho eseguito un **TCP SYN scan** (-sS, detto anche "half-open scan") per scoprire quali porte fossero aperte. Questo tipo di scansione richiede privilegi di root perché manda pacchetti SYN grezzi senza completare l'handshake TCP, ed è quindi più rapido e meno rumoroso di un connect scan.

Il risultato è stato impressionante: ben **22 porte aperte**, fra cui servizi notoriamente sensibili come FTP (21), Telnet (23), SMB (139, 445), MySQL (3306), PostgreSQL (5432), VNC (5900), X11 (6000) e diversi servizi *r-services* legacy (512, 513, 514). Già a colpo d'occhio si capisce che siamo davanti

a una macchina pensata per essere attaccata.

```
(kali@kali)-[~]
$ sudo nmap -sS 192.168.1.100
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-07 10:00 -0400
Nmap scan report for 192.168.1.100 (192.168.1.100)
Host is up (2.6s latency).
Not shown: 978 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8180/tcp  open  unknown
MAC Address: 08:00:27:13:2C:A8 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 12.87 seconds
```

Figura 2 — Risultato del TCP SYN scan: 22 porte aperte sul target.

Cosa ho osservato:

- Numero abnorme di porte aperte rispetto a un host normale.
- Presenza di protocolli in chiaro (FTP, Telnet, rsh/rlogin) che oggi sarebbero gravi anche da soli.
- Servizi di database (MySQL, PostgreSQL) esposti direttamente sulla rete.

Step 4 — Service & version detection

```
$ sudo nmap -sV 192.168.1.100
```

Sapere che una porta è aperta è solo metà del lavoro: per cercare vulnerabilità note serve la **versione** del servizio in ascolto. Con `-sV` Nmap interroga ogni porta aperta e tenta di identificare il software e la versione, basandosi su un database di firme.

Le versioni emerse sono particolarmente datate, e questa è la cosa più interessante: **vsftpd 2.3.4**, **OpenSSH 4.7p1**, **Apache httpd 2.2.8**, **Samba smbd 3.x**, **MySQL 5.0.51a**, **PostgreSQL 8.3**, **UnrealIRCd**, oltre a una bindshell in ascolto sulla 1524 etichettata letteralmente *"Metasploitable root shell"*: una backdoor esplicita.


```
(kali@kali)-[~]
$ sudo nmap -sV 192.168.1.100
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-07 10:03 -0400
Nmap scan report for 192.168.1.100 (192.168.1.100)
Host is up (0.55s latency).
Not shown: 978 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet?
25/tcp    open  smtp?
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec?
513/tcp   open  login?
514/tcp   open  shell?
1099/tcp  open  java-rmi       GNU Classpath grmiregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ccproxy-ftp?
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8180/tcp  open  unknown
MAC Address: 08:00:27:13:2C:A8 (Oracle VirtualBox virtual NIC)
Service Info: Host: irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 207.45 seconds
```

Figura 3 — Versioni dei servizi rilevate da `nmap -sV`.

Cosa ho osservato:

- vsftpd 2.3.4 — versione storicamente compromessa da una backdoor pubblica (CVE-2011-2523).
- Apache httpd 2.2.8 — release del 2008, fuori supporto da anni.
- UnrealIRCd sulla 6667 — nota per un trojan inserito a monte nei tarball ufficiali (CVE-2010-2075).
- Una **bind shell** sulla 1524 è di fatto già una backdoor pronta all'uso.

Step 5 — Ricerca di exploit pubblici per Apache 2.2.8

```
$ searchsploit apache 2.2.8
```

Con la versione di Apache in mano, ho usato **searchsploit** per interrogare la mia copia locale di Exploit-DB. L'output è una lista di exploit pubblici applicabili (in tutto o in parte) ad Apache 2.2.8 e a componenti correlate come `mod_ssl`, Tomcat e Struts.

Il valore di questo step è capire il **percorso** mentale: dalla porta aperta → al banner del servizio → alla versione → alle CVE e agli exploit pronti. È così che si passa da "questa macchina ha Apache aperto" a "questa macchina ha un'attack surface concreta e documentata".

```
(kali@kali)-[~]
$ searchsploit apache 2.2.8
```

Exploit Title	Path
Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Remote Code Executio	php/remote/29290.c
Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code Execution + Scan	php/remote/29316.py
Apache < 2.0.64 / < 2.2.21 mod_setenvif - Integer Overflow	linux/dos/41769.txt
Apache < 2.2.34 / < 2.4.27 - OPTIONS Memory Leak	linux/webapps/42745.py
Apache CXF < 2.5.10/2.6.7/2.7.4 - Denial of Service	multiple/dos/26710.txt
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuck.c' Remote Buffer Ov	unix/remote/21671.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer	unix/remote/47080.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer	unix/remote/764.c
Apache OpenMeetings 1.9.x < 3.1.0 - '.ZIP' File Directory Trav	linux/webapps/39642.txt
Apache Struts 2 < 2.3.1 - Multiple Vulnerabilities	multiple/webapps/18329.txt
Apache Struts 2.0.1 < 2.3.33 / 2.5 < 2.5.10 - Arbitrary Code E	multiple/remote/44556.py
Apache Struts < 1.3.10 / < 2.3.16.2 - Classloader Manipulation	multiple/remote/41690.rb
Apache Struts2 2.0.0 < 2.3.15 - Prefixed Parameters OGNL Injec	multiple/webapps/44583.txt
Apache Tomcat < 5.5.17 - Remote Directory Listing	multiple/remote/2061.txt
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal	unix/remote/14489.c
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal (PoC)	multiple/remote/6229.txt
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 -	jsp/webapps/42966.py
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 -	windows/webapps/42953.txt
Apache Xerces-C XML Parser < 3.1.2 - Denial of Service (PoC)	linux/dos/36906.txt
Webroot Shoutbox < 2.32 (Apache) - Local File Inclusion / Rem	linux/remote/34.pl

```
Shellcodes: No Results
```

Figura 4 — Exploit pubblici noti per Apache 2.2.8 (Exploit-DB via searchsploit).

Cosa ho osservato:

- Diversi exploit per mod_ssl ("OpenFuck", buffer overflow remoti).
- Vulnerabilità in Tomcat associate alla stessa stack (Directory Traversal, CVE multiple).
- Possibili RCE Apache+PHP versioni < 5.3.12 / 5.4.2.

Step 6 — OS fingerprinting

```
$ sudo nmap -O 192.168.1.100
```

Con -O Nmap deduce il **sistema operativo** del target analizzando piccole differenze nello stack TCP/IP (TTL iniziale, opzioni TCP, gestione dei flag, ecc.) e confrontandole con un database di *fingerprint*.

Il risultato conferma quanto sospettato dai banner: il target è **Linux con kernel 2.6.x** (range 2.6.9 – 2.6.33). Il kernel 2.6 è stato dichiarato end-of-life nel 2016, quindi parliamo di una base di sistema operativo tutt'altro che aggiornata.

```
MAC Address: 08:00:27:13:2C:A8 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 24.98 seconds
```

Figura 5 — OS detection: Linux kernel 2.6.9–2.6.33.

Step 7 — Scansione aggressiva (-A -T4)

```
$ sudo nmap -A -T4 192.168.1.100
```

La flag -A attiva insieme la *service/version detection*, l'OS detection, il *traceroute* e una serie di script NSE di default. -T4 alza il timing template per velocizzare la scansione (adatta a una LAN affidabile come la mia).

L'output è molto ricco. Tra i dettagli che ho trovato più rilevanti: il server FTP vsftpd 2.3.4 permette il login anonimo (codice FTP 230), il banner HTTP del web server è Apache/2.2.8 (Ubuntu) DAV/2, il certificato SSL di PostgreSQL è *scaduto nel 2010*, NFS espone diversi programmi RPC, e Samba dichiara apertamente smbld 3.0.20-Debian con *message signing disabled*.

```
(kali@kali)-[~]
$ sudo nmap -A -T4 192.168.1.100
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-07 10:28 -0400
Nmap scan report for 192.168.1.100 (192.168.1.100)
Host is up (0.040s latency).
Not shown: 978 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.1.69
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet?
25/tcp    open  smtp         Postfix smtpd
|_ smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
53/tcp    open  domain       ISC BIND 9.4.2
| dns-nsid:
|_  bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_ http-title: Metasploitable2 - Linux
111/tcp   open  rpcbind      2 (RPC #100000)
| rpcinfo:
|   program version   port/proto  service
|   100000  2             111/tcp     rpcbind
|   100000  2             111/udp     rpcbind
|   100003  2,3,4         2049/tcp    nfs
|   100003  2,3,4         2049/udp    nfs
|   100005  1,2,3         33427/tcp   mountd
|   100005  1,2,3         54813/udp   mountd
|   100021  1,3,4         43725/tcp   nlockmgr
|   100021  1,3,4         48328/udp   nlockmgr
```

Figura 6 — Scansione aggressiva, parte 1/3 (FTP, SSH, SMTP, DNS, HTTP, RPC).

```

| 100024 1 44726/udp status
|_ 100024 1 56787/tcp status
139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp open exec?
513/tcp open login?
514/tcp open shell?
1099/tcp open java-rmi GNU Classpath grmiregistry
1524/tcp open bindshell Metasploitable root shell
2049/tcp open nfs 2-4 (RPC #100003)
2121/tcp open ccproxy-ftp?
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5
| mysql-info:
| Protocol: 10
| Version: 5.0.51a-3ubuntu5
| Thread ID: 9
| Capabilities flags: 43564
| Some Capabilities: Support41Auth, ConnectWithDatabase, SupportsTransactions, LongColumnFlag,
Speaks41ProtocolNew, SupportsCompression, SwitchToSSLAfterHandshake
| Status: Autocommit
|_ Salt: lUE9/lH2^fdC_88QnVB*
5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-date: 2026-05-07T14:32:45+00:00; -2s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvince
Name=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
5900/tcp open vnc VNC (protocol 3.3)
| vnc-info:
| Protocol version: 3.3
| Security types:
|_ VNC Authentication (2)
6000/tcp open X11 (access denied)
6667/tcp open irc UnrealIRCd
8180/tcp open unknown
MAC Address: 08:00:27:13:2C:A8 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE:
cpe:/o:linux:linux_kernel

Host script results:
| smb-os-discovery:
| OS: Unix (Samba 3.0.20-Debian)
| Computer name: metasploitable

```

Figura 7 — Scansione aggressiva, parte 2/3 (Samba, MySQL, PostgreSQL, VNC, X11, IRC).

```

5432/tcp open  postgresql      PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-date: 2026-05-07T14:32:45+00:00; -2s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvince
Name=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
5900/tcp open  vnc                  VNC (protocol 3.3)
|_vnc-info:
|_  Protocol version: 3.3
|_  Security types:
|_    VNC Authentication (2)
6000/tcp open  X11                  (access denied)
6667/tcp open  irc                  UnrealIRCd
8180/tcp open  unknown
MAC Address: 08:00:27:13:2C:A8 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE:
cpe:/o:linux:linux_kernel

Host script results:
|_smb-os-discovery:
|_  OS: Unix (Samba 3.0.20-Debian)
|_  Computer name: metasploitable
|_  NetBIOS computer name:
|_  Domain name: localdomain
|_  FQDN: metasploitable.localdomain
|_  System time: 2026-05-07T10:31:00-04:00
|_clock-skew: mean: 1h19m59s, deviation: 2h18m35s, median: -1s
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_smb-security-mode:
|_  account_used: guest
|_  authentication_level: user
|_  challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_smb2-time: Protocol negotiation failed (SMB2)

TRACEROUTE
HOP RTT      ADDRESS
1   39.88 ms  192.168.1.100 (192.168.1.100)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submi
t/ .
Nmap done: 1 IP address (1 host up) scanned in 293.68 seconds

```

Figura 8 — Scansione aggressiva, parte 3/3 (smb-os-discovery, smb-security-mode, traceroute).

Cosa ho osservato dallo scan aggressivo:

- **FTP anonimo abilitato** — chiunque può collegarsi senza credenziali.
- Certificato SSL di PostgreSQL **scaduto da anni** (validità 2010).
- SMB con message signing disabled — flag esplicita di rischio ("dangerous, but default").
- Hostname rivelato: metasploitable.localdomain, computer name metasploitable.
- Clock skew di oltre un'ora rispetto allo scanner: utile per attacchi che dipendono dal tempo (es. Kerberos).

Step 8 — NSE: scansione vulnerabilità con script vuln

```
$ nmap --script vuln 192.168.1.100
```

Per chiudere la fase Nmap ho lanciato lo script set vuln, che esegue tutti gli script NSE marcati come "vuln". Sono script che tentano effettivamente di confermare la presenza di una vulnerabilità nota (non si limitano a guardare il banner). La scansione ha richiesto circa **9 minuti** ed è quella che ha prodotto l'output più ricco di tutta l'esercitazione.

Riassumo qui sotto le vulnerabilità più gravi trovate, raggruppate per tipo. L'output completo dello script è allegato come file di testo (Output nmap --script vuln Meta.txt).

Porta / Servizio	Vulnerabilità	CVE / ID	Impatto
21 / vsftpd 2.3.4	Backdoor smiley face	CVE-2011-2523	RCE come root
1099 / Java RMI	Default config class loading	—	Esecuzione codice remota
6667 / UnrealIRCd	Trojan upstream	CVE-2010-2075	RCE remota
25 / SMTP	POODLE	CVE-2014-3566	MitM, recupero plaintext
25 / SMTP	Anonymous DH / Logjam	CVE-2015-4000	Downgrade TLS, MitM
5432 / PostgreSQL	CCS Injection	CVE-2014-0224	Hijack di sessione TLS
5432 / PostgreSQL	Weak DH group + POODLE	CVE-2014-3566	MitM, intercettazione
80 / HTTP	TRACE abilitato + dir esposte	—	XST, info disclosure
80 / HTTP	CSRF su DVWA / Mutillidae	—	Cross-Site Request Forgery

Tabella 1 — Sintesi delle vulnerabilità rilevate da nmap --script vuln.

8.1 Approfondimento sulle vulnerabilità critiche

vsFTPD 2.3.4 backdoor (CVE-2011-2523)

Lo script ftp-vsftpd-backdoor ha confermato la presenza della famosa backdoor introdotta nel codice di vsftpd 2.3.4: inviando uno smiley :) nel campo username il server apre una shell sulla porta 6200 con privilegi di root. Nmap ha persino eseguito id e ricevuto uid=0(root) gid=0(root), che è la conferma esecutiva della compromissione totale del sistema.

Java RMI registry RCE (porta 1099)

Il registro RMI accetta il caricamento di classi da URL remoti: un attaccante può caricare codice Java arbitrario ed eseguirlo nel contesto del processo. È un classico delle macchine Metasploitable e c'è un modulo Metasploit dedicato.

UnrealIRCd backdoor (CVE-2010-2075)

Nel 2009 la distribuzione ufficiale di UnrealIRCd è stata trojanizzata a monte: alcune release contenevano una backdoor che permette esecuzione di comandi remota. La versione presente sulla 6667 è esattamente quella vulnerabile.

Cluster di problemi SSL/TLS (porte 25 e 5432)

POODLE, Logjam, Anonymous Diffie-Hellman, CCS Injection e gruppi DH deboli sono tutti problemi della crittografia di trasporto. Singolarmente possono sembrare minori, ma combinati permettono a un attaccante in posizione di MitM di degradare le connessioni e leggere o manipolare il traffico.

Step 9 — Scansione finale con Nessus Essentials

Per concludere ho lanciato una **Basic Network Scan** di Nessus puntando sempre a 192.168.1.100. Nessus copre molti più controlli applicativi rispetto a Nmap e categorizza le vulnerabilità per gravità secondo il **CVSS v3.0**.

Al termine, la dashboard mostrava **35 vulnerabilità totali**, ordinate dalla più grave (magenta = Critical) alla meno grave (azzurro = Info). Tra quelle in alto: **Bind Shell Backdoor Detection** (Critical, CVSS 9.8), **Samba Badlock Vulnerability** (High, CVSS 7.5), problemi multipli su **phpMyAdmin**, **ISC Bind**, **HTTP**, **SMB**, **PHP** e altre famiglie.

L'organizzazione di Nessus per *famiglia* (Backdoors, CGI abuses, DNS, Web Servers, ecc.) e la presenza di metriche come VPR ed EPSS rendono questo output decisamente più "da report" rispetto a quello di Nmap, ed è il motivo per cui in azienda viene usato come strumento standard di vulnerability management.

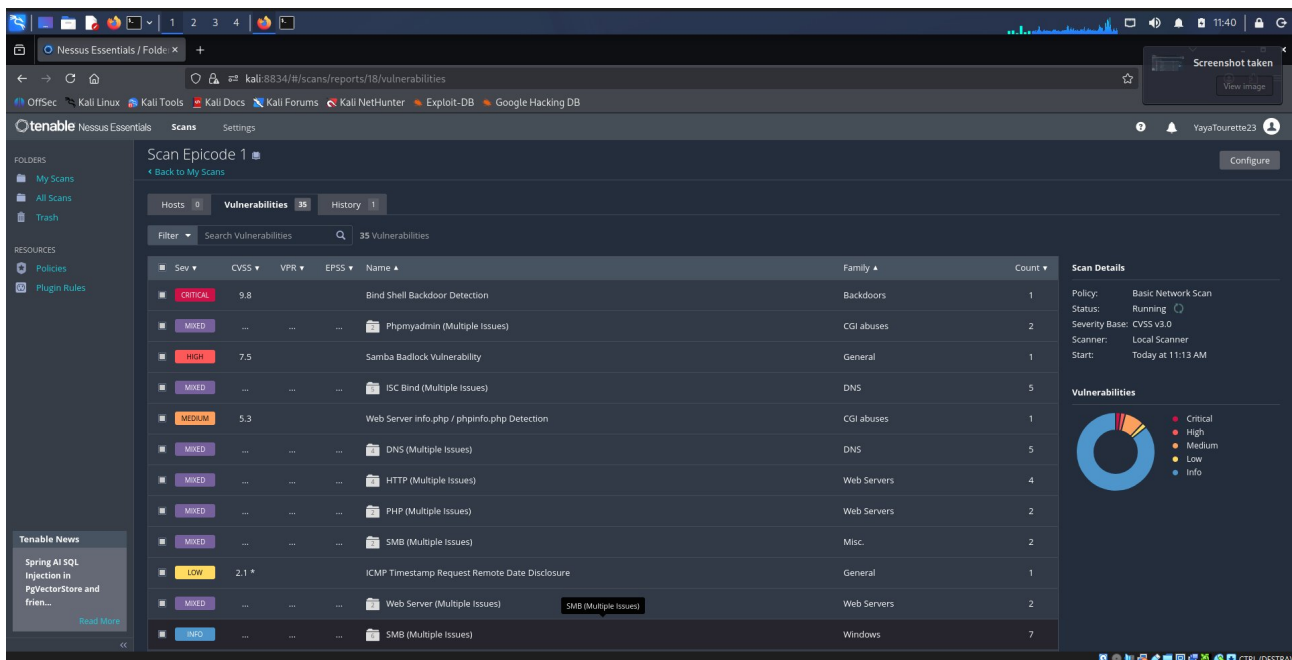


Figura 9 — Dashboard Nessus Essentials: 35 vulnerabilità rilevate sul target, ordinate per gravità.

Cosa ho osservato:

- **Bind Shell Backdoor Detection** — Critical, CVSS 9.8 (la stessa porta 1524 vista con Nmap).
- **Samba Badlock** — High, CVSS 7.5.
- **phpMyAdmin (Multiple Issues)** — conferma che l'esposizione di pannelli amministrativi è di per sé un rischio.
- Web Server info.php / phpinfo.php — Medium, classico information disclosure.
- Decine di issue Info/Low che, pur non gravi singolarmente, completano il quadro.

5. Riepilogo dei risultati

Mettendo insieme i risultati dei due scanner, il quadro complessivo del target è chiaro: **Metasploitable 2 è un sistema completamente compromesso in più punti**, con almeno tre vie di ingresso che portano direttamente a una shell di root (vsftpd, RMI, UnrealIRCd) e una quarta che è di fatto una backdoor pre-installata (ingreslock sulla 1524). A queste si aggiungono una decina di problemi TLS/SSL, vulnerabilità web, applicazioni didatticamente vulnerabili come DVWA e Mutillidae, e protocolli legacy in chiaro.

In un sistema reale, ognuna di queste sole vulnerabilità sarebbe da considerarsi incidente di sicurezza grave; qui ne convivono decine, esattamente come previsto dal progetto formativo della macchina.

6. Risultati ottenuti

L'obiettivo dell'esercitazione è stato **raggiunto**. Ho condotto in autonomia tutte le fasi previste dalla traccia (configurazione di rete, host discovery, scansione delle porte, version detection, ricerca di exploit pubblici, OS fingerprinting, scansione aggressiva, NSE script vuln e infine scan Nessus) e per ciascuno step ho potuto leggere e interpretare l'output, collegando le informazioni di livello "basso" (porta, banner, versione) a vulnerabilità concrete, identificate da CVE pubbliche.

7. Difficoltà incontrate

Non ho incontrato difficoltà di rilievo. La parte più lenta è stata la scansione --script vuln, che ha richiesto diversi minuti perché esegue molti controlli attivi; al di là di questo il flusso è andato liscio. Il punto che ho dovuto curare di più è stato l'*ordine* dei comandi: lanciare searchsploit ha senso solo dopo aver ottenuto la versione del servizio con -sV, e Nessus ha senso lanciarlo dopo aver capito manualmente cosa aspettarsi, altrimenti la dashboard rischia di sembrare soltanto una lista lunghissima e poco leggibile.

8. Conclusioni

Questa esercitazione mi ha permesso di mettere in pratica il flusso di lavoro tipico delle prime fasi di un penetration test: *discovery*, *enumeration*, *vulnerability scanning*. La vera lezione, secondo me, non è tanto saper lanciare Nmap o Nessus — quello è il "come" — ma capire **cosa** stanno dicendo. Nmap mi ha insegnato a leggere il sistema dall'esterno (porte, banner, fingerprint), Nessus mi ha mostrato come questa stessa lettura possa essere strutturata, prioritizzata e presentata in un report professionale.

Un'altra cosa che mi porto via è il rispetto per il contesto etico: gli stessi comandi che ho usato qui in laboratorio, eseguiti su una rete altrui, costituirebbero un illecito. Saperli usare implica anche sapere quando *non* usarli.

Come passo successivo, la naturale evoluzione di questo lab sarebbe spostarsi dalla fase di *vulnerability assessment* a quella di *exploitation* vera e propria, ad esempio sfruttando con Metasploit la backdoor di vsftpd rilevata, per chiudere il cerchio dal banner all'accesso effettivo.